PORTSWIGGER LAB COMPLETION REPORT

Path Traversal

Name: Muhammad Afnan K O

Focus: WAPT

Platform: portswigger.com

1. Objective — What was the task about?

The objective of these six labs was to understand path traversal vulnerabilities in web applications and learn how attackers may access files outside the intended directory. The practical exercises focused on identifying insecure file-handling mechanisms and understanding how different input-validation techniques can be bypassed.

2. Concept/Understanding — What did you learn?

The main concept of path traversal is to understand how access files which are outside the given directory by exploiting the vulnerabilities. It occurs when user controlled inputs is used to access files without proper validation or access controls, this vulnerability arises from misconfiguration of authorization. This lab tells how attackers manipulate different file paths to access server details. I learned about traversal sequences, absolute path bypasses, non-recursive filtering, URL encoding, path validation, and null byte bypasses. The exercises also highlighted the importance of secure input validation and proper file-access restrictions.

3. Practical Work — What did you perform?

I completed a total of 6 labs in path traversal which are

1. **File path traversal, simple case**
2. **File path traversal, traversal sequences blocked with absolute path bypass**
3. **File path traversal, traversal sequences stripped non-recursively**
4. **File path traversal, traversal sequences stripped with superfluous URL-decode**
5. **File path traversal, validation of start of path**
6. **File path traversal, validation of file extension with null byte bypass**.

In the first lab I understood how to get /etc/passwd directory o f a linux server by changing the file name of a product image in the url which gave all the details from /etc/passwd file.

In the second lab same method as first but there is no need to exit the current directory , by explicitly giving the file name it gives the information in response.

In the third lab this lab strips the path traversal inputs so we applied the techniques twice , where it only strips the values which matches the givenand rest is uploaded to server , which is instead of this ”../../../etc/passwd” this is used “….//….//….//etc/passwd” this bypassed the stripping and got the details.

In the fourth lab the input were url encoded when sending it to the server so the symbols will be stripped , so the enoded version of the input I sgiven ehich gave the details of /etc/passwd file.

Eg:- “..%252f..%252f..%252fetc/passwd “

In the fifth lab the method is same , but here the parameter is not given , the direct path is given , so in this we modify the url to get access to the etc/passwd, then it shows the info.

Eg:- “ url= /var/www/image/../../../etc/passwd “

In the sixth lab the methods are same , but un here the response is only image or only image format is supported so we gave a .png at the end after a symbol it gave the details in response

Eg:- “ filename?=../../../etc/passwd%00.png “

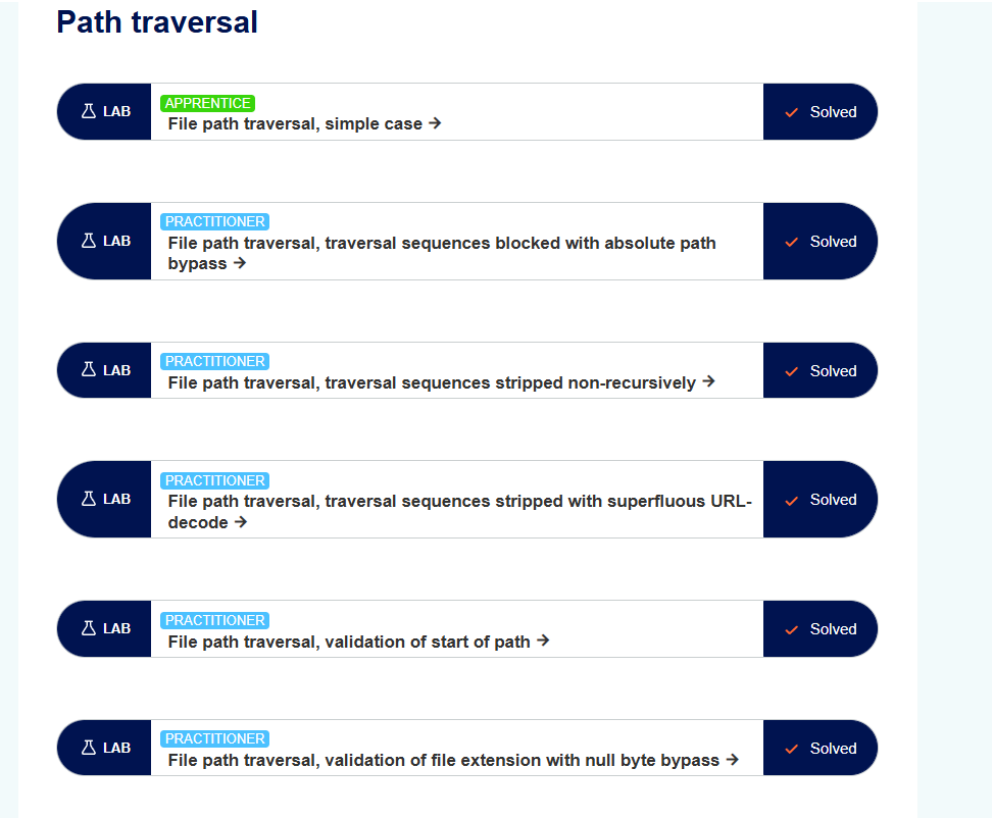
4. Tools Used — Tools used during the task.

- Portswigger website
- Browser Developer tools
- Burpsuite
- url decoder/encoder

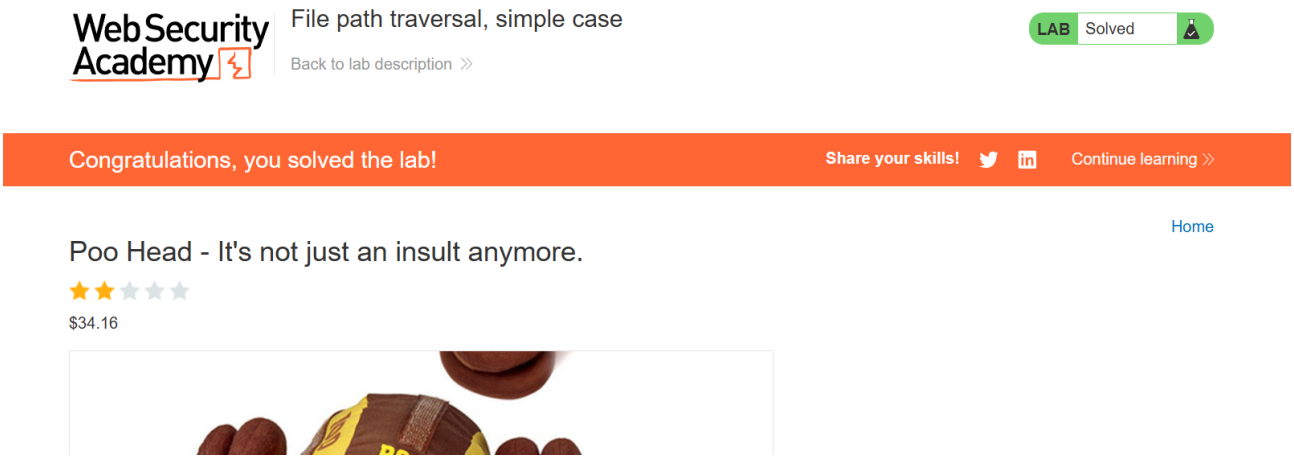
5. Evidence — Relevant screenshots and results.

Screenshots of the completed TryHackMe rooms, practical exercises, and relevant results can be added below as evidence of the work completed.

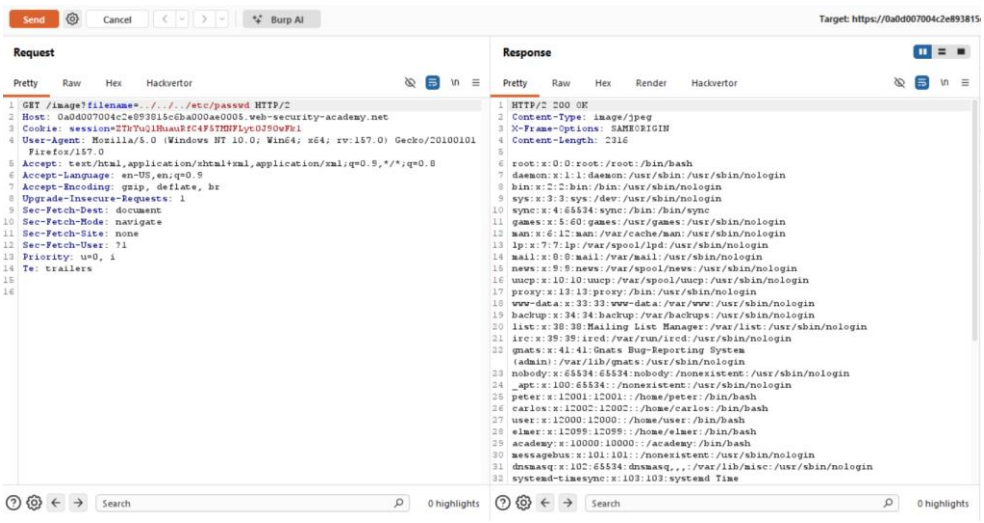
1.API Testing all lab completion:-



2.Screenshot of Room_1 . **File path traversal, simple case** completion:-

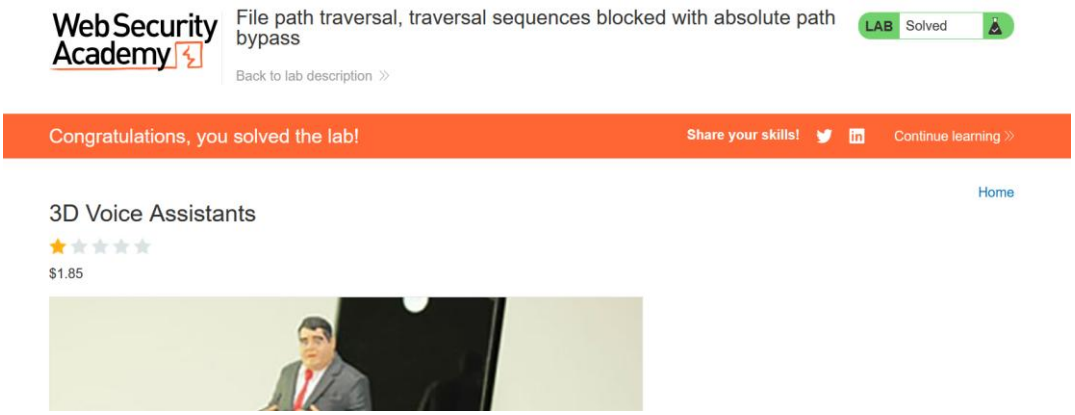


3.Screenshot of File traversal output:-

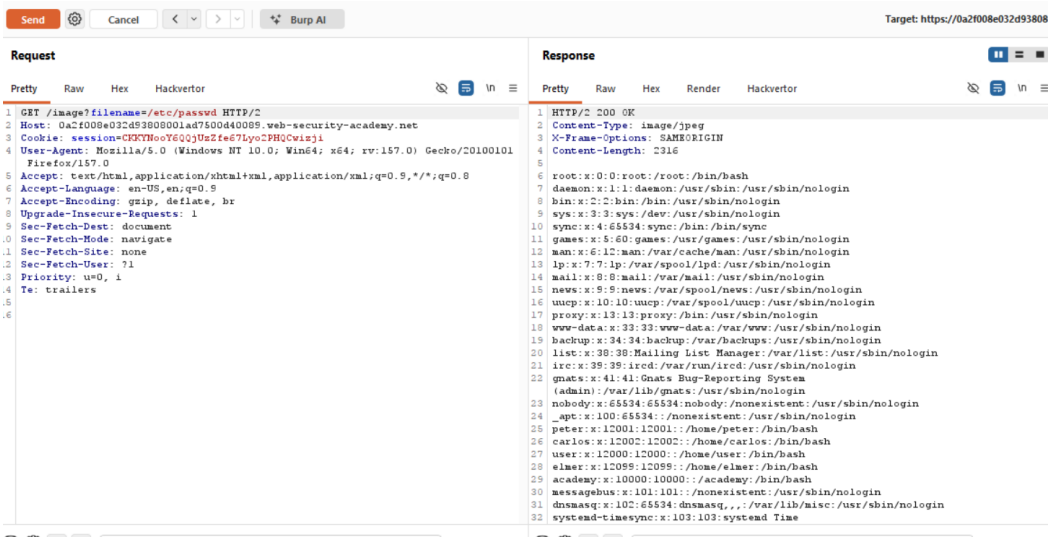


4.Screenshot of Room_2 [File path traversal, traversal sequences blocked with absolute path bypass]

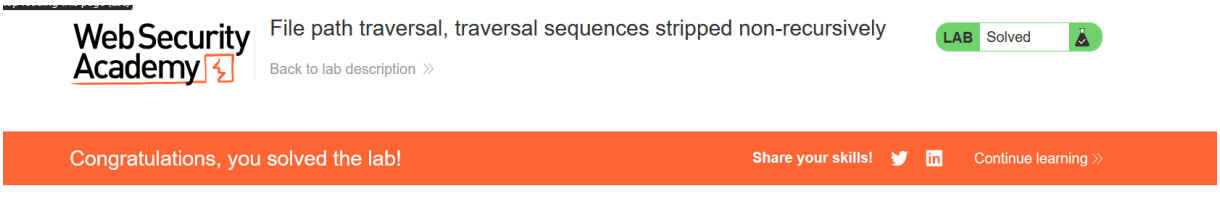
Completion:-



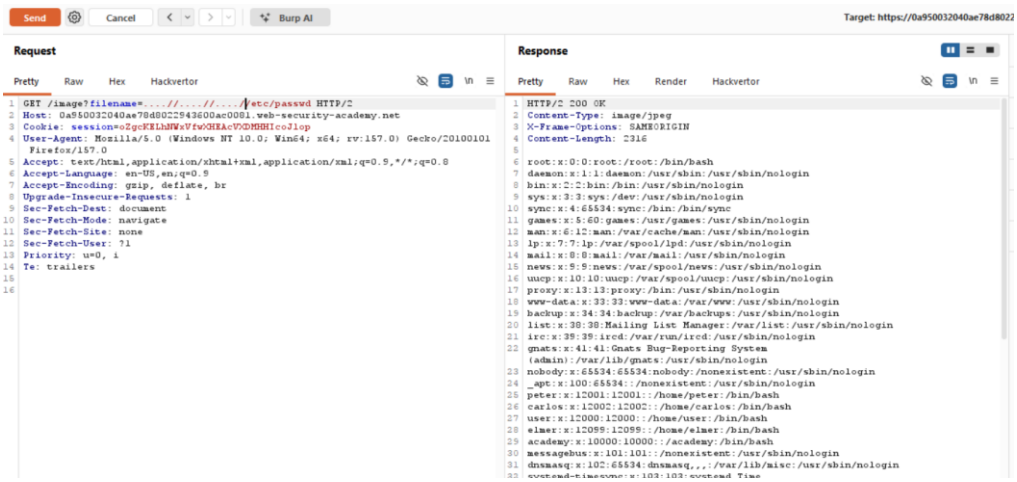
5.Screenshot of File Traversal output:-



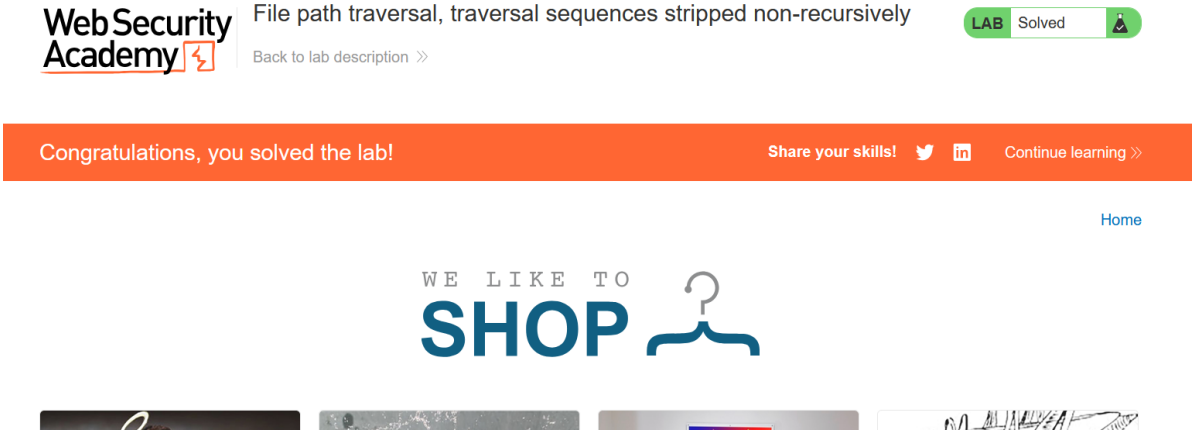
7.Screenshot of Room_3 . **File path traversal, traversal sequences stripped non-recursively** **Completion:-**



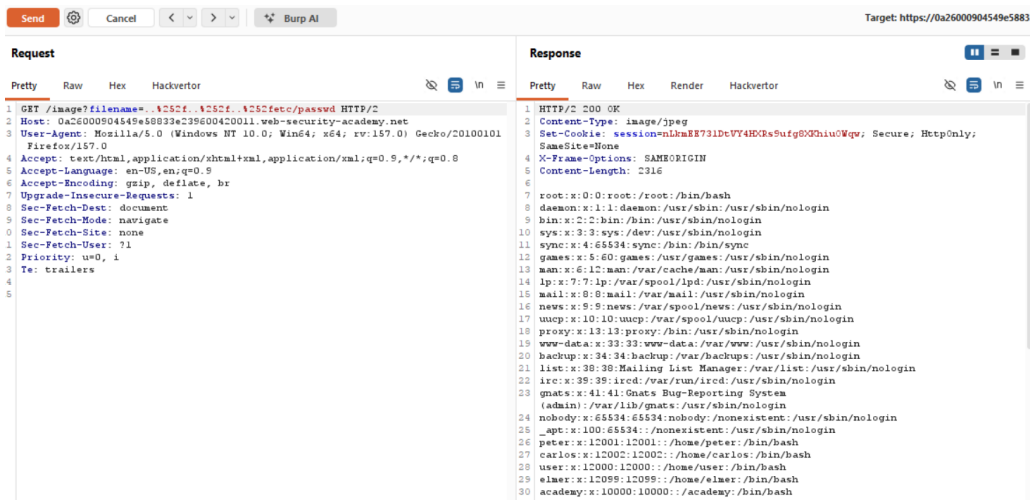
8. Screenshot ofFile traversal ouput with bypassing stripping:-



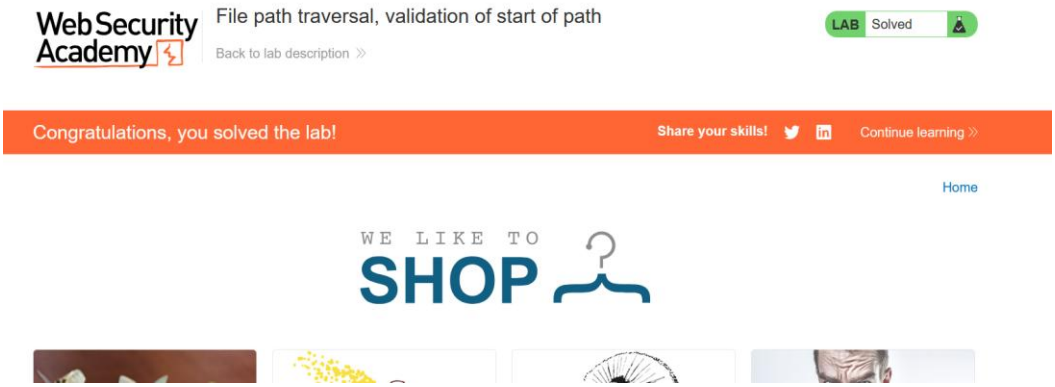
9.Screenshot of Room_4 File path traversal, traversal sequences stripped with superfluous URL-decode
Completion:-



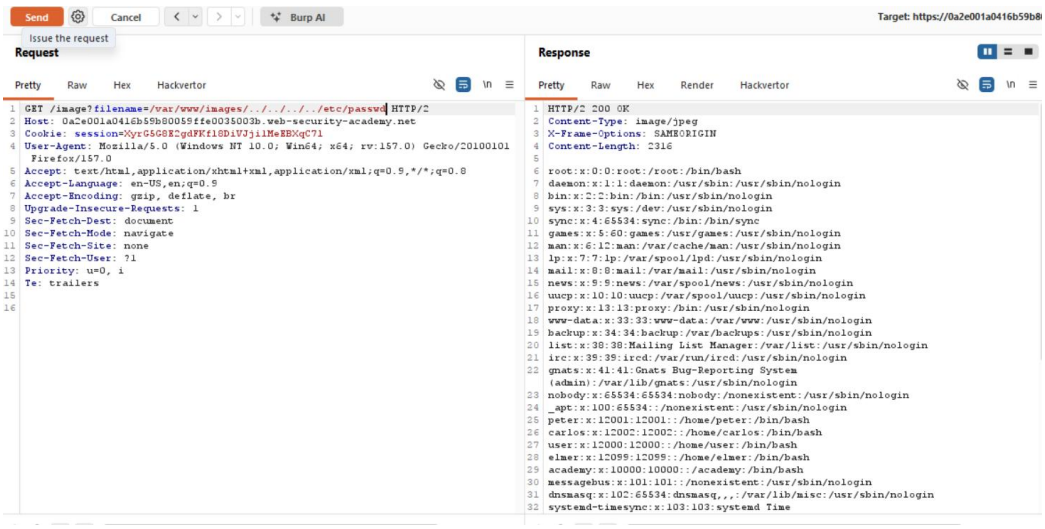
10.Screenshot of file traversal with url encoded values:-



11.Screenshot of Room_5 [File path traversal, validation of start of path] Completion:-

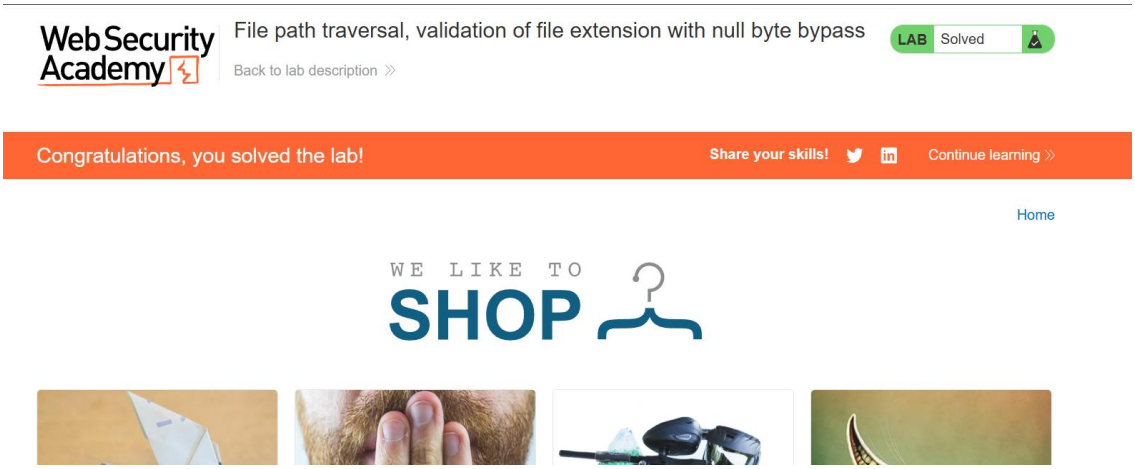


12.Screenshot of file traversal with null byte extension:-

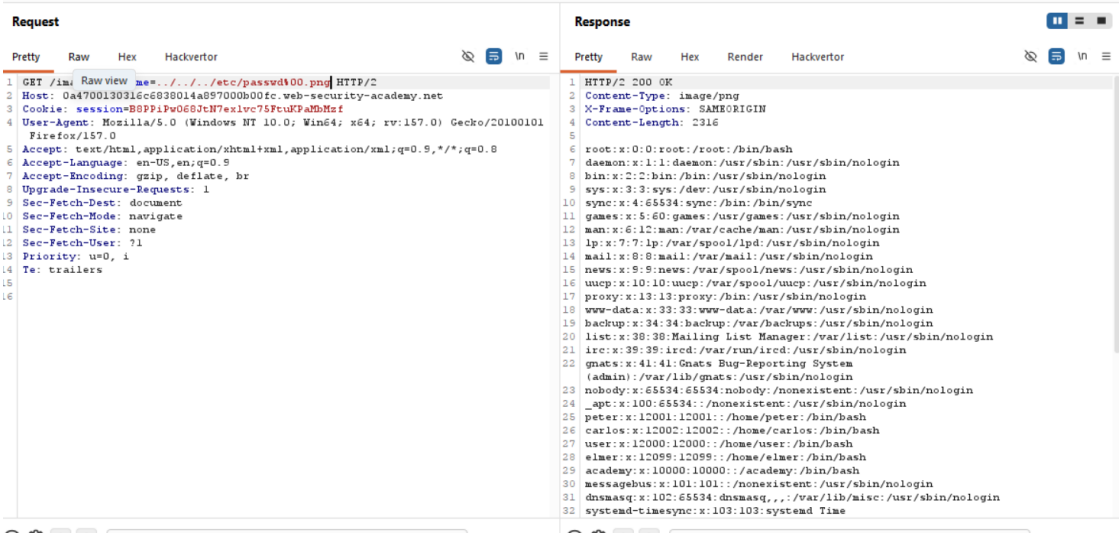


13.Screenshot of Room_6 [File path traversal, validation of file extension with null byte bypass]

Completion:-



14.Screenshot of file traversal output:-



6. Result — What did you achieve or discover?

By completing these labs helped me to understand the path traversal vulnerability better and increase my expertise in penetration testing career, while completing these lab I understood the types of path traversal and the ways to prevent the path traversal attack and also to bypass the stripping and url encoding .

7. Key Learnings — What did you learn from the task?

- Understood the meaning and basic working of Path Traversal vulnerabilities.
- Learned How to exploit the file traversal vulnerability to get sensitive datas.
- Lack of authorization or authorization misconfiguration leads to the cause of path traversal vulnerability.
- Also understood the websites also accepts the url encoded data where the string is sanitized.

Conclusion

Completing these six Path Traversal labs improved my understanding of file-access vulnerabilities and common validation weaknesses in web applications. I learned how different filtering and encoding techniques can affect security checks. The exercises also highlighted the importance of validating file paths securely and restricting access to authorized directories. Overall, the labs strengthened my practical web application security testing skills and awareness of secure file-handling practices.